이재학

서버 · 네트워크 구축, 로그 수집부터
관제 환경 구축 및 보안 점검 자동화까지의 경험

로그와 관제

로그 수집 · ELK · Wazuh · Splunk로 공격 흐름을 시간순으로 재구성

방어 설계

구간별 허용 목록 · 단계별 방화벽 · XSS 방어 · TLS 4구간

점검 자동화

주정통 점검 241개 항목 · Ansible 점검 → 조치 · 보안 토글 13개

Email ljx1565@gmail.com

개인 서버
https://www.cardspace.duckdns.org

GitHub
https://github.com/ljx1565

학력

학교	전공 · 구분	기간
De La Salle University Dasmariñas (필리핀)	멀티미디어 디자인학과 4학년 중퇴	2013.08 – 2022.08
고등학교 검정고시	졸업	2025.05 – 2025.05

자격

자격	발급 기관	취득
네트워크관리사 2급	한국정보통신자격협회 (ICQA)	2026.06
리눅스마스터 2급	한국정보통신진흥협회 (KAIT)	2026.08
TOEIC 755점	YBM 한국TOEIC위원회	2026.02

네트워크관리사 · 리눅스마스터 취득으로 네트워크 · 서버 운영의 기본기를 다졌고,
다음 목표로 정보처리기사와 정보보안기사를 준비하고 있습니다.

교육

과정	내용	기간
정보보안 전문가 과정 **메가스터디 AI 캠퍼스**	네트워크 · 리눅스 · 파이썬 → 서버 구축 → 보안 장비 · 웹 해킹 → 관제 솔루션 → 인프라 보안 실습	2026.04 – 2026.10 (7개월)

과정 중 프로젝트	역할	주요 담당 업무	기간
1차 · 사내 인프라 구축과 통합 관리 시스템	인프라 설계 및 구축	토폴로지 · 서버 사양 설계, 논리 · 물리 구성도, DNS · Nginx · php-fpm 분리 구성, Ubuntu 자동화 코드, 로그 정책	2026.06 (2주)
2차 · 쇼핑몰 서비스 보안 관제	보안 로그 관제팀 팀장	주정통 점검 도구 메인 코드 및 일부 점검 모듈, 서버 로그 수집 · 상관분석 탐지 룰, 관제 결과 보고서	2026.08 (2주)
3차 · 대학 IT 인프라 침투 테스트와 보안관제	서버 구축 및 보안	웹 · 메일 서버 구축과 이중화, 방화벽 단계별 정책 · XSS 방어 · SSL/TLS, Ansible playbook, 주정통 점검 → 조치 연결	2026.09 – 10 (3주)

7개월 동안 네트워크 · 리눅스 · 파이썬 기초부터 서버 구축, 방화벽 · IDS/IPS 운영, 로그 · 패킷 분석, 웹 해킹 실습, ELK · Wazuh 관제 환경 구축까지 직접 실습했습니다. 이 과정에서 로그를 분석하는 습관과 자동화 운영 능력을 키웠습니다.

기술 스택

인프라
03 – 04

HAProxy Reverse Proxy · LoadBalancing · 헬스체크
Keepalived VRRP로 VIP 이중화 · MASTER 장애 시 인수
Cisco VLAN · OSPF · ACL로 구역 분리
ESXi · Xen 역할별 포트그룹 분리
Linux · Windows Rocky · Ubuntu · Windows Server 운영

03 인프라 구성 · 망 분리
04 고가용성 · 무중단 전환

로그 수집
05 – 06

rsyslog facility · imfile 수집 · 디스크 큐 전송
auditd 명령 실행(EXECVE) 기록
Filebeat → Logstash grok 필드 분리 · GeoIP
Elasticsearch 로그 종류별 인덱스
Prometheus file_sd로 수집 대상 관리
Wazuh agent 1514/tcp · AES 전송

05 서버 로그 설정
06 중앙 수집 · 저장

관제
07 – 14

Kibana KQL 탐지 규칙 · /healthz 정상 잡음 분리
Splunk 경고 규칙 · 공격 흐름 시간순 재구성
Wazuh FIM · 자동 차단 · ATT&CK 매핑
Grafana · Zabbix 가용성 · ICMP 손실 · 인터페이스
Snort · Suricata 자체 룰 · SID 대역 관리
Python 상관분석 탐지 룰 9개

07 관제 환경 · 수집 구조
08 ELK Stack · 로그 관제
09 Wazuh · 호스트 관제
10 지표 관제 · 가용성
11 퍼플 검증 · 공격 → 탐지
12 로그 기반 분석
13 탐지 룰 · 오탐 분석
14 장애 분석 · 트러블슈팅

보안 · 암호화
15 – 17

iptables INVALID → F2B → BLACKLIST → 허용 → LOG → DROP
firewalld rich rule 화이트리스트
fail2ban 4xx · 429 반복 시 1시간 차단
SELinux enforcing · 필요한 boolean만
ModSecurity WAF 감사 로그
사설 Root CA 4개 구간 TLS · CA 검증

15 다계층 방어 · 보안 전 → 후
16 접근 통제 · 차단 정책
17 웹 공격 방어 · 구간 암호화

자동화 · 점검
18 – 20

Ansible 역할별 플레이북 · --check 미리보기 · 한 대씩 적용
Python paramiko · netmiko 원격 병렬 점검
주정통 241개 항목 자동화 · 13개 자동 조치

18 주정통 진단 자동화 · 설계
19 주정통 진단 자동화 · 결과와 조치
20 정책 배포 자동화 · Ansible

인프라 구성 · 망 분리

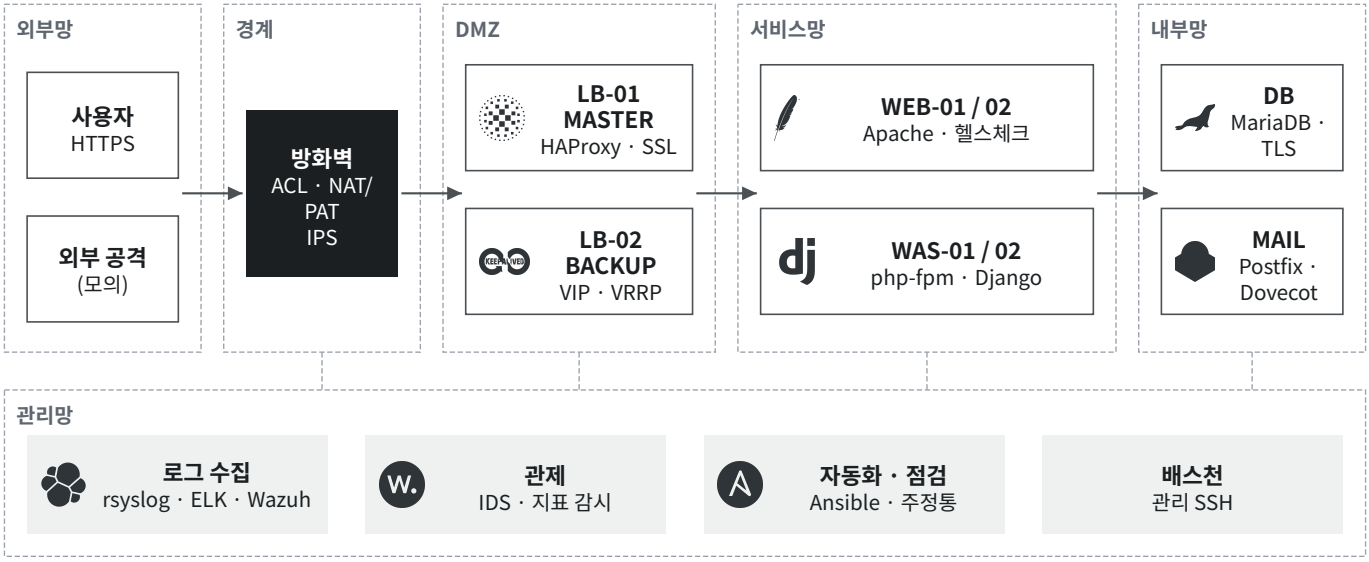
문제
서비스 · 관리 · 감시 트래픽이 한 망에 섞이면 통제와 관제가 어려움

한 일
외부 · DMZ · 서비스 · 내부 · 관리망으로 분리하고 구간마다 허용 목록 작성

결과
구간별 허용 포트만 통과 · 관리 접속과 감시는 관리망 주소에서만

상세 → 부록 A-2

표준 망 분리 구성



점선 = 로그 전송 · 감시 · 배포 경로 (관리망 주소에서만 허용)

구간별 허용 정책

구간	허용	그외
외부 → LB	HTTPS 443 (80은 443으로 전환)	기록 후 DROP
LB → WEB	서비스 포트 · LB 두 대에서만	WEB 직접 접속 차단
WEB → WAS	php-fpm 9000 · WEB에서만	기록 후 DROP
WAS · MAIL → DB	3306 TLS · 지정 서버만	기록 후 DROP
관리망 → 전 구간	SSH(비표준 포트) · SNMP · 로그 전송	root 원격 접속 차단

가상화 · 네트워크

영역	다룬 내용	영역	다룬 내용
가상화	ESXi 포트그룹 · vSwitch · Xen	스위치	VLAN · 액세스 포트 · 트렁크
라우팅 · OS	OSPF · ACL · Rocky · Ubuntu · Windows Server	서버 NIC	본딩 active-backup · 링크 감시

고가용성 · 무중단 전환

문제
LB 한 대 장애나 포트 변경에 서비스가 멈출 위험

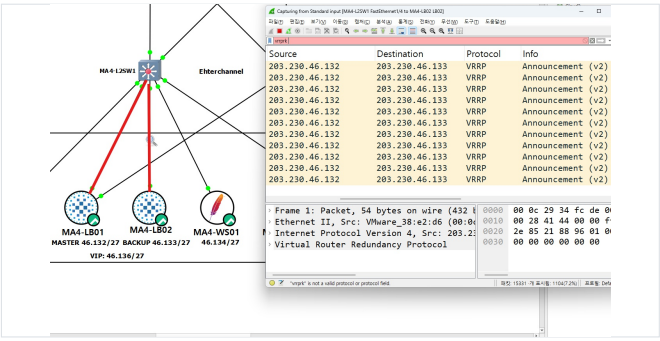
한 일
VRRP 이중화 · 헬스체크 · 단계 배포

결과
VIP가 예비 LB로 넘어가도 서비스 유지 · 무중단 포트 전환

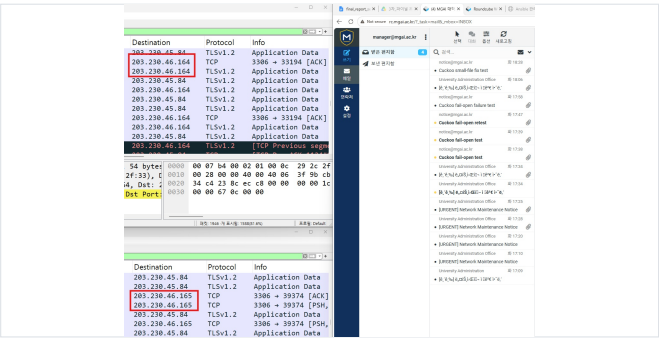
상세 → 부록 A-2

서비스 흐름 · 장애 시 동작



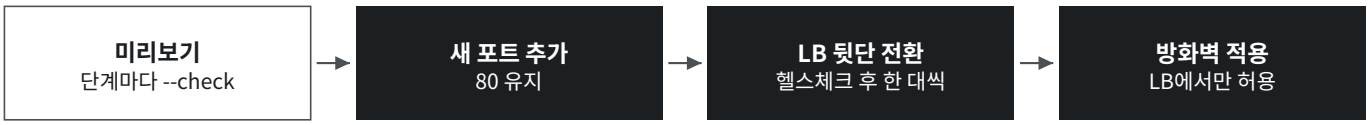


VRRP 광고 · LB-01 MASTER (VIP)



WAS 두 대가 번갈아 처리 · 세션 유지

무중단 단계 배포 · 웹 서비스 포트 80 → 35439




```
[root@lb01 ~]# grep -n "server " /etc/haproxy/haproxy.cfg
18:     timeout server          60s
33:     server ws01 203.230.46.134:35439 check
34:     server ws02 203.230.46.135:35439 check
43:     server postdov 203.230.44.36:2525 send-proxy check-send-proxy
```

HAProxy 뒷단 → WEB :35439

```
[root@lb02 ~]# ip a
------------------------------중간 생략------------------------------
3: ens224: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1450 qdisc mq state UP group default qlen
    link/ether 00:0c:29:34:fc:de brd ff:ff:ff:ff:ff:ff
    altname enp19s0
    inet 203.230.46.133/27 brd 203.230.46.159 scope global noprefixroute ens224
       valid_lft forever preferred_lft forever
    inet 203.230.46.136/27 scope global secondary ens224
       valid_lft forever preferred_lft forever
```

LB-02 · VIP가 secondary로 붙음 = VIP가 예비 LB로 넘어온 상태 (장애 전환 확인)

서버 로그 설정

문제
서비스마다 로그 위치와 형식이 달라 한곳에서 볼 수 없음

한 일
syslog를 쓰는 서비스는 facility로, 파일에만 쓰는 서비스는 imfile로 수집 · 디스크 큐로 전송

결과
서비스별 로그를 중앙 서버에 송신 서버별로 수신 · 실제 클라이언트 IP 기록

상세 → 부록 A-1

주요 서비스별 기본 설정

서비스	로그	수집방식	설정요점
HAProxy	/dev/log → local2	syslog	log /dev/log local2 · 전용 파일로 분리 후 & stop (이중 기록 방지)
Apache	사이트별 access · error	imfile	Tag · Facility local6 · XFF로 실제 클라이언트 IP 기록
php-fpm	error.log	imfile	오류(err)만 전송
MariaDB	slow log · server_audit	imfile	여러 줄 로그는 startmsg.regex로 한 건씩 묶음
ModSecurity	modsec_audit.log	imfile	WAF 감사 로그를 그대로 전송
Postfix · Dovecot	maillog	syslog	programname 필터 · 지연 · 반송 · 오류만 전송
커널 · 방화벽	[IPT BLOCK] 등	syslog	차단 로그는 접두어로 구분

syslog 형식과 imfile 형식

syslog 형식 · 서비스가 직접 syslog로 기록

```
# haproxy.cfg
global
    log /dev/log local2
# /etc/rsyslog.d/49-haproxy.conf
local2.*    -/var/log/haproxy.log
& stop
# 모든 facility를 중앙으로
*.* call to_log01
```

imfile 형식 · 파일에만 기록하는 서비스

```
module(load="imfile")
input(type="imfile"
  File="/var/log/httpd/error_log"
  Tag="httpd-error:" Facility="local6"
  Severity="err" ruleset="to_log01")
input(type="imfile"
  File="/var/log/php-fpm/error.log"
  Tag="php-fpm:" ruleset="to_log01")
```

전송과 수신

```
ruleset(name="to_log01") {
    action(type="omfwd" target="203.230.44.194" port="514" protocol="tcp"
           template="RSYSLOG_ForwardFormat"
           queue.type="LinkedList" queue.filename="fwd_log01"
           queue.maxDiskSpace="500m" queue.saveOnShutdown="on"
           action.resumeRetryCount="-1" action.resumeInterval="10")
}

# 시스템 로그 전부
*.* call to_log01
```

1

보내는 쪽 · ① 디스크 큐 + 무한 재시도 (중앙 서버 장애 시 유실 방지)

받는 쪽 · 송신 서버 IP / 프로그램별 파일

```
module(load="imtcp")
input(type="imtcp" port="514"
      ruleset="ops_remote")
template(name="OpsRemoteFile"
  string="<수집 경로>/%FROMHOST-IP%/
          %PROGRAMNAME%.log")
```

중앙 수집 · 저장

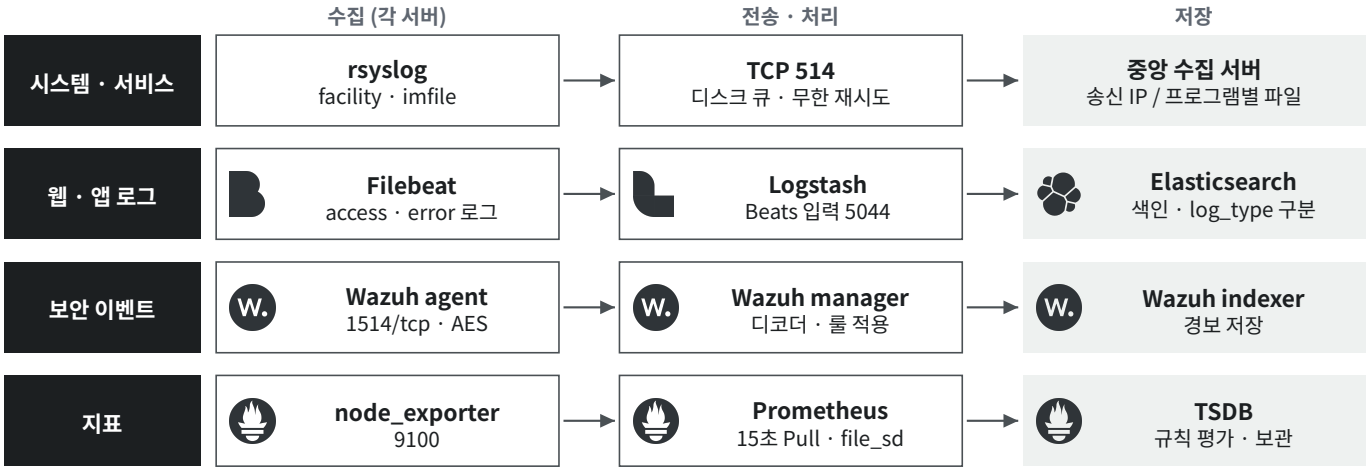
문제
로그 종류마다 형식과 양이 달라 한 저장소로 모으기 어려움

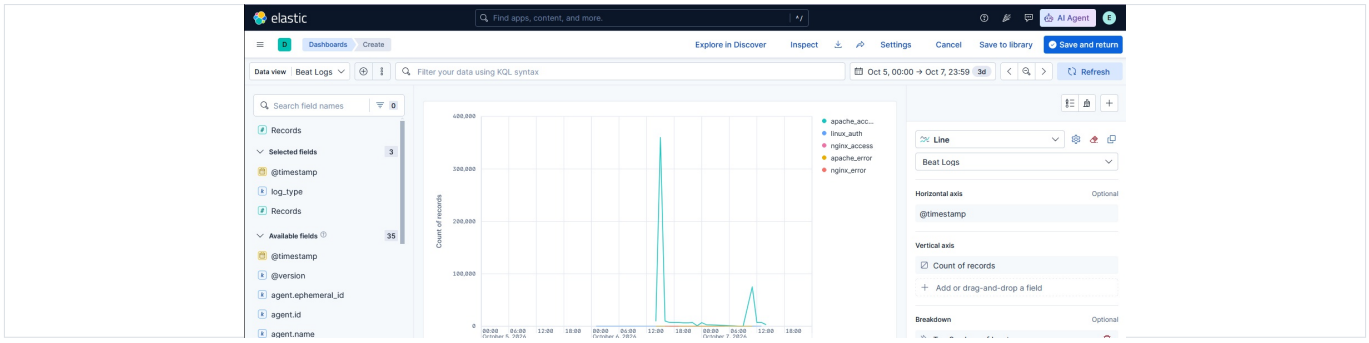
한 일
시스템 로그는 rsyslog, 웹 로그는 Filebeat → Logstash, 보안 이벤트는 Wazuh agent, 지표는 Prometheus로 경로 분리

결과
경로별 중앙 저장 · log_type별 수집량으로 누락 확인

상세 → 부록 A-1

수집 경로 4가지





수집 확인 · Kibana Beat Logs 데이터 뷰 · log_type별 수집량 (apache_access · linux_auth · nginx_access · error)

Prometheus · 수집 대상 (prometheus.yml)

```
global:
  scrape_interval: 15s
rule_files:
  - /etc/prometheus/rules/*.yml
scrape_configs:
  - job_name: node_exporter
    file_sd_configs:
      - files: ['/etc/prometheus/targets/*.yml']
  - job_name: windows
```

대상 목록은 파일로 분리 · 서버를 추가해도 설정 재시작 없이 반영

Wazuh agent · 관리 서버 등록 (ossec.conf)

```
<client>
  <server>
    <address>MANAGER_IP</address>
    <port>1514</port>
    <protocol>tcp</protocol>
  </server>
  <crypto_method>aes</crypto_method>
</client>
```

에이전트 → 관리 서버 1514/tcp · AES 암호화 전송

관제 환경 · 수집 구조

문제
로그 · 경고 · 지표를 한 도구에 모으면 그 경로가 끊길 때 사건을 재구성할 수 없음

한 일
원본 보존(rsyslog) · 검색(ELK) · 경고(Splunk) · 호스트(Wazuh) · 지표(Prometheus · Zabbix)로 경로 분리

결과
경로별 송수신 점검 기준 · 시험 메시지로 끝까지 도착 확인

상세 → 부록 A-1

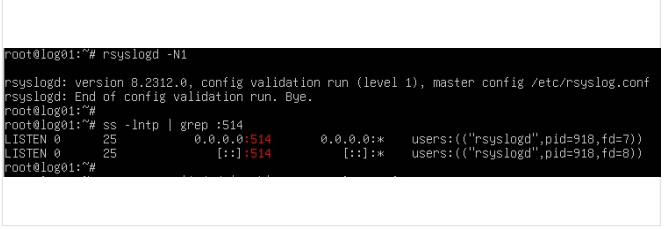
목적별로 나눈 수집 경로

	보내는 쪽 (대상 서버 · 장비)		받는 쪽		보는 곳
로그 원본 보존	rsyslog	TCP 514	LOG01 · 중앙 파일 보존	→	서버별 · 프로그램별 원본 파일
로그 검색 · 시각화	Filebeat	TCP 5044	Logstash → Elasticsearch	→	Kibana 검색 · 대시보드
보안 경고 · 상관분석	Splunk UF	TCP 9997	Splunk 인덱서	→	경고 규칙 · 시간순 조사
호스트 보안 이벤트	Wazuh agent	TCP 1514	Wazuh manager	→	룰 경보 · 자동 대응
서버 지표	node_exporter	Pull 9100	Prometheus	→	Grafana 대시보드 · 경보
NAT 내부 서버 · 장비	Zabbix agent · SNMP	10051 · 161	Zabbix	→	가용성 · ICMP · 트래픽

원본 보존 · 검색 · 경고 · 지표를 한 도구에 몰지 않고 목적별 경로로 나눔 → 한 경로가 끊겨도 다른 경로로 사건을 재구성할 수 있음

수집 경로 점검 · 보낸 로그가 실제로 도착했는가

증상	확인 순서	판단 기준
이벤트가 안 보임	송신 서비스 → 방화벽 · NAT → 수신 리스너	시험 메시지가 끝까지 조회되는지
상태는 미확인 · 지표는 있음	가용성 값 → 에이전트 하트비트	수집 수치와 상태 판단 신호를 분리
Splunk 수집 공백	마지막 이벤트 → UF 연결 통계 → 9997	연결 기록과 대상 로그 생성 시각 대조



LOG01 · rsyslog 설정 검사와 TCP 514 수신 대기



DB01의 시험 메시지가 송신 IP 경로에 저장됨 (끝까지 도착 확인)

ELK Stack · 로그 관제

문제
서버마다 흩어진 웹 · 인증 로그로는 공격 흐름을 한눈에 볼 수 없음

한 일
Logstash grok으로 필드 분리 · GeoIP · 로그 종류별 인덱스, Kibana 대시보드와 KQL 탐지 규칙 작성

결과
웹 · 메일 이벤트 대시보드 · 탐지 규칙 4개 · /healthz 정상 잡음 분리

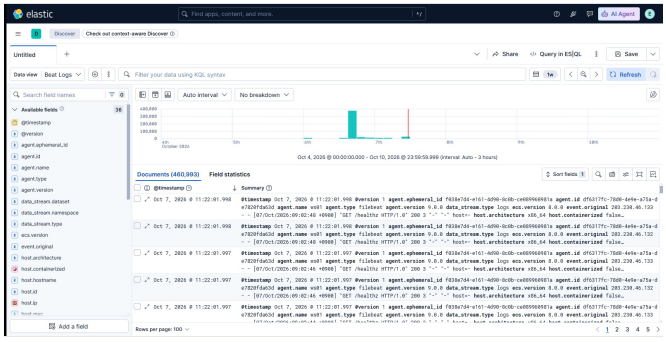
상세 → 부록 A-1

Logstash 파이프라인 · 필드 분리와 인덱스 분리

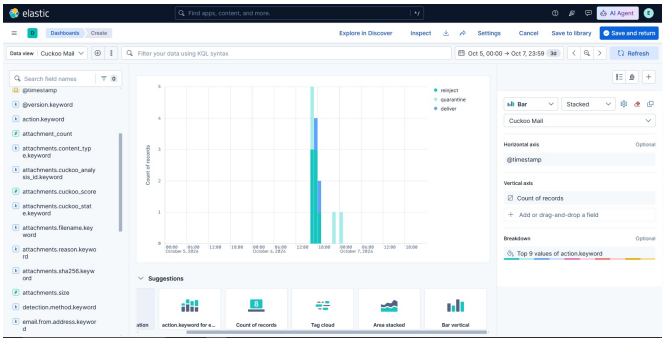
```
input  { beats { port => 5044 } }
filter {
  if [log_type] == "apache_access" {
    grok  { match => { "message" => "%{COMBINEDAPACHELOG}" } }
    date  { match => [ "timestamp", "dd/MMM/yyyy:HH:mm:ss Z" ] }
    geoip { source => "[source][address]" }
  }
}
output { elasticsearch { hosts => ["https://ES:9200"]  index => "logs-%{[log_type]}-%{+YYYY.MM.dd}" } }
```

원문 한 줄을 출발지 IP · URL · 응답 코드 · User-Agent 필드로 분리 → 필드 단위 검색 · 집계 · 탐지 규칙에 사용

Kibana 탐지 규칙	조건 (KQL)	임계
웹 로그인 무차별 대입	url.path : "/login/" and http.response.status_code : (401 or 403 or 500)	같은 IP · 5분 20회
SQL Injection 시도	url.query : (*union* or *select* or *%27*)	1회
스캐너 User-Agent	user_agent.original : (*sqlmap* or *nikto* or *gobuster*)	1회
상태 확인 요청 제외	not (url.path : "/healthz" and source.ip : (LB01 or LB02))	정상 잡음 분리



Kibana · Filebeat가 보낸 WS01 웹 접근 원문 · 반복되는 /healthz 요청과 LB01 · LB02 출발지를 정상 기준으로 분리



Kibana · 메일 필터 이벤트를 action별(격리 · 배달 · 재주입)로 시각화

캡처 추가 · Kibana 탐지 규칙 경보
Security → Alerts 화면: 위 규칙이 만든 경보 목록 (규칙 이름 · 심각도 · 출발지 IP) + 경보 하나를 펼쳐 원본 로그로 이동한 화면

Wazuh · 호스트 관제

문제
호스트 안의 파일 변경 · 인증 공격 · 취약 패키지는 네트워크 장비로 보이지 않음

한 일
에이전트 배포 · FIM · SCA · 취약점 탐지 · 자체 룰 · 자동 대응 · ATT&CK 매핑

결과
웹셸 업로드 즉시 경보 · SSH 무차별 대입 자동 차단 · 탐지를 ATT&CK 기술로 정리

상세 → 부록 A-1

사용한 기능

기능	설정	확인한 결과
파일 무결성 (FIM)	웹 루트 실시간 · /etc 주기 감시	웹 루트에 파일이 생기면 즉시 경보 (웹셸 업로드 탐지)
보안 설정 점검 (SCA)	CIS 벤치마크 정책	서버별 점수 확인 → 조치 후 재점검 {{점수 입력}}
취약점 탐지	설치 패키지 ↔ CVE 매칭	Critical · High 패키지 목록 → 업데이트 {{건수 입력}}
자동 대응	firewall-drop · 룰 5763	SSH 인증 실패 반복 IP를 180초 차단
ATT&CK 매핑	룰마다 technique 표시	T1110 무차별 대입 · T1505.003 웹셸 · T1595 스캔

local_rules.xml · 자체 룰

```
<group name="local,web,">
  <rule id="100100" level="10"
        frequency="20" timeframe="300">
    <if_matched_sid>31101</if_matched_sid>
    <same_source_ip />
    <description>웹 4xx 반복 - 스캔 의심</description>
    <mitre><id>T1595</id></mitre>
  </rule>
</group>
```

같은 출발지의 4xx 응답 5분 20회 → 레벨 10 경보 · ATT&CK T1595

ossec.conf · FIM · 자동 대응

```
<syscheck>
  <directories realtime="yes" check_all="yes">/var/www/
html</directories>
  <directories check_all="yes">/etc</directories>
</syscheck>
<active-response>
  <command>firewall-drop</command>
  <location>local</location>
  <rules_id>5763</rules_id>
  <timeout>180</timeout>
</active-response>
```

룰 5763 = 120초 안에 SSH 인증 실패 8회

캡처 추가 · 에이전트 · 경보 추이
Wazuh 대시보드 첫 화면: 에이전트 목록 (활성) + 최근 24시간 경보 수 · 레벨별 그래프

캡처 추가 · FIM 경보
웹 루트에 테스트 파일(웹셸 모의)을 올린 직후 Integrity monitoring 이벤트 상세 (파일 경로 · 해시 · 시간)

캡처 추가 · ATT&CK 매핑
MITRE ATT&CK 모듈 화면: 탐지된 technique 목록 (T1110 · T1505.003 · T1595)

지표 관제 · 가용성

문제
장비 · 서버 응답과 자원 상태를 한곳에서 보지 못함

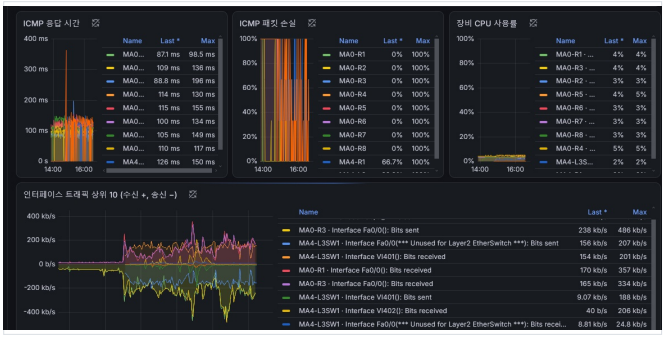
한 일
Prometheus(Pull) · Zabbix(Active) · SNMP로 수집 방향을 나누고 Grafana로 통합 · 경보 규칙

결과
장비 7대 응답 상실 즉시 식별 · 수집 장애와 서비스 장애 구분

상세 → 부록 A-1



Grafana · 서버별 CPU · 메모리 · 디스크 · 네트워크 (Prometheus)

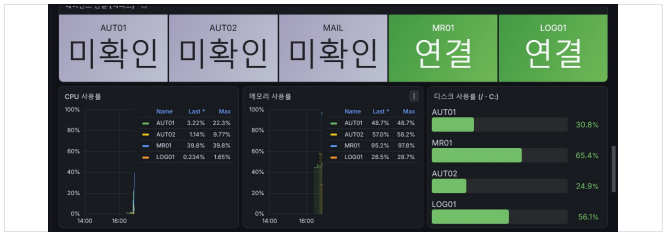


Grafana · 장비 ICMP 응답 · 손실 · 인터페이스 트래픽 (Zabbix · SNMP)



가용성 시험 중 MA0 장비 7대 DOWN · ICMP 손실 100% · 같은 시각 다른 3개 지점은 UP → 영향 구간을 좁힘

관측	확인한 사실	다음 확인
응답 상실	장비 7대 DOWN · 손실 100%	장비 콘솔 · 인터페이스 · 구역 간 경로
정상 지점	경계 · DMZ 장비는 UP 유지	서비스 영향 범위와 응답 유지 구간
원인 구분	CPU · HSRP · 앱 응답은 별도 지표	같은 시간축으로 대조한 뒤 원인 확정



NAT 내부 서버 · 상태 카드는 미확인이지만 CPU · 메모리는 수신 → 하트비트 문제로 구분

Prometheus · 경보 규칙

```
- alert: HostDown
  expr: up{job=~"node_exporter|windows"} == 0
  for: 1m
- alert: MemoryLow
  expr: node_memory_MemAvailable_bytes
        / node_memory_MemTotal_bytes < 0.10
```

수집 대상 응답 끊김 1분 · 가용 메모리 10% 미만

퍼플 검증 · 공격 → 탐지

문제
규칙을 만들어도 실제 공격을 잡는지 알 수 없음

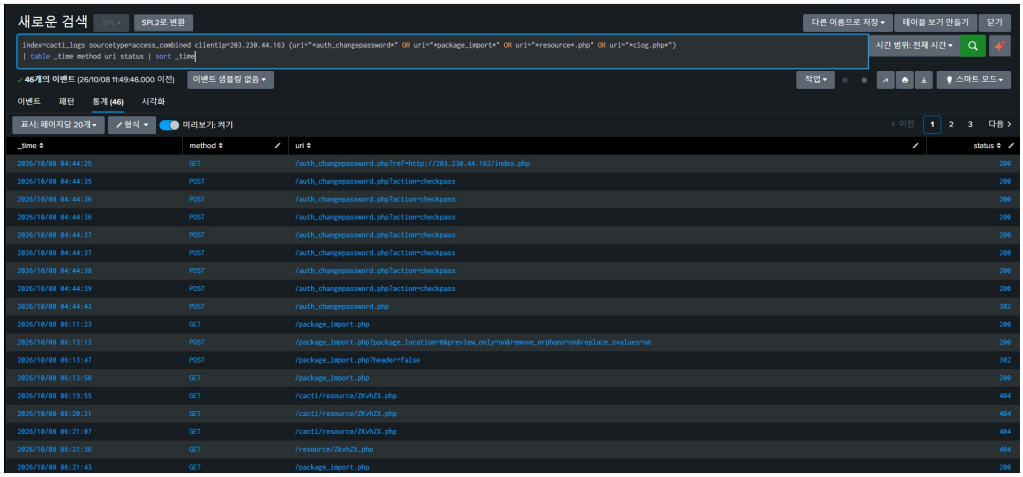
한 일
무결성 · 기밀성 · 가용성 시나리오를 공격하고 로그 · 경보 · 대응을 같은 시간축에서 확인

결과
시나리오별 관측 지점과 조치 확정 · Cacti 공격 흐름을 Splunk로 시간순 재구성

상세 → 부록 A-1

시나리오	공격 경로 (레드)	관측 (블루 · 퍼플)	판단 · 대응
무결성	공문형 피싱 → 관리 단말 → Cacti 패키지 Import → 학사 DB	Splunk · Cacti 요청 46건 시간순 재구성 · DB 레코드 전후 대조	관리 출발지 제한 · Cacti 패치 · DB 계정 권한 축소
기밀성	게시판 XSS · 가짜 CAPTCHA → 단말 실행 → FTP · SMB	인증 로그 · ModSecurity 403 · 감사 로그	입력 검증 · 평문 FTP 제거 · 공유 권한 점검
가용성	위장 실행 파일 → 봇 세션 → 시험 트래픽	Zabbix · 장비 7대 DOWN · ICMP 손실 100%	경계 ACL · 제어면 보호 · HSRP 확인
메일	악성 시험 첨부	Amavis · ClamAV 격리 · ELK Cuckoo Mail 이벤트	격리 + 정상 메일 배달 확인
호스트	SSH 무차별 대입 · 웹셸 업로드	Wazuh 5763 · FIM	자동 차단 · 즉시 경보 {{시간}}

HTTP 200은 요청 처리, 로그인 성공은 인증, 명령 출력은 실행을 뜻함 → 화면의 상태값을 실제 의미로 나눠 읽고, 시각 · 자산 · 계정을 연결 키로 사건을 재구성



Splunk · 관리 단말 → Cacti 요청을 시간순으로: 비밀번호 변경 → 패키지 Import → 같은 PHP 경로 200 응답 4건 (실행 여부는 서버 세션 증적과 대조)

Suricata · 자체 룰 (IPS drop)

```
drop http $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (msg:"SQL Injection - Repeated Single Quote Probe";
  flow:established,to_server; http.uri; content:"%27"; nocase;
  detection_filter:track by_src, count 5, seconds 60; classtype:web-application-attack; sid:2001011; rev:1;)
```

같은 출발지에서 60초 안에 5회 이상이면 차단 · SID 대역으로 룰 분류 (2XXXXXX = 웹)

로그 기반 분석

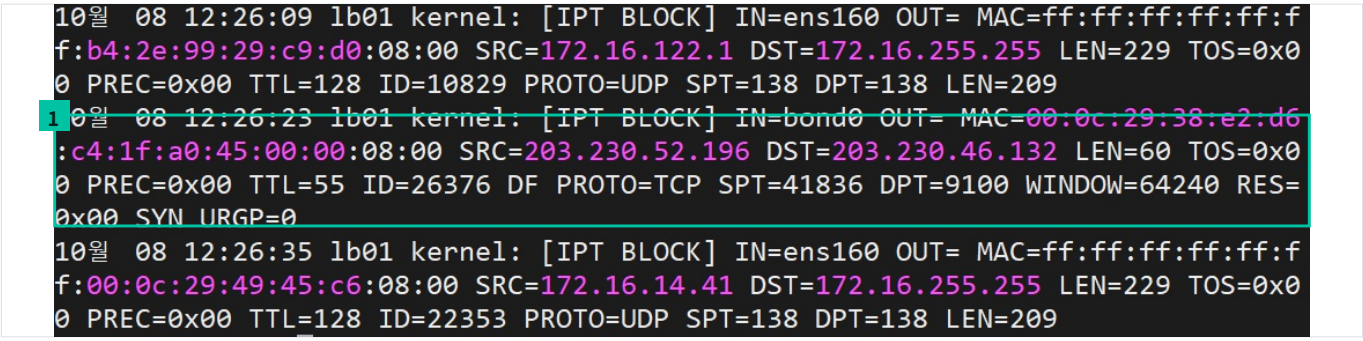
문제
설정을 바꾸기 전에 누가 무엇을 쓰는지 모름

한 일
메일 · 인증 · 차단 · 접근 로그를 출처별로 추적

결과
메일 중계 범위 축소 · 인증 장애 원인 특정 등 5건 조치

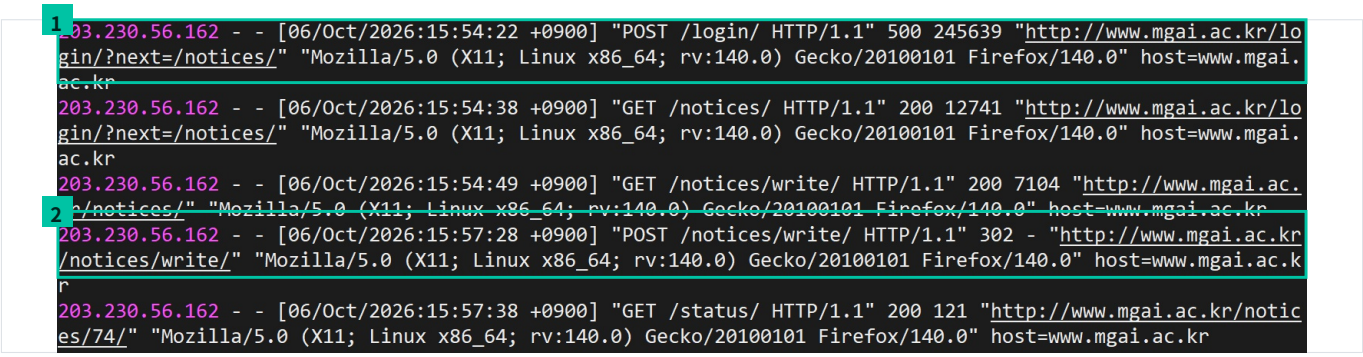
상세 → 부록 A-1

로그 출처	발견	조치 · 결과
메일 서버 smtpd · Dovecot 로그	중계 허용 범위가 /16 대역 전체 → 같은 대역의 외부 메일 서버도 인증 없이 중계 가능	**정상 사용처(WAS 두 대 · 내부 재주입)만 확인 후 축소 · 인증은 TLS 후에만 → 외부 중계 거부 확인**
웹메일 · Dovecot 인증 실패 로그	'Temporary authentication failure' → SQL 인증 조회 시간 초과 → DB 방화벽이 메일 서버 → 3306 차단	**DB 허용 규칙 추가 → 로그인 정상**
LB iptables [IPT BLOCK] 로그	외부 대역 → tcp/9100 시도 (수신 서비스 없음) 와 관리망 IGMP · NetBIOS 브로드캐스트 (정상 잡음) 구분	**의심 트래픽만 추적 대상 · 잡음은 규칙으로 분리**
웹 access_log	포트 축소 직후 내부 사용자 접속 끊김 → 로그에서 NAT 포트 포워드 경로(:80) 사용 확인	**해당 경로만 재허용 · 포트 폐쇄 전 로그 확인을 절차로 추가**
방화벽 규칙 · 패킷 출발지	SNMP · SSH 허용이 감시 서버 실제 주소로 되어 있으나 DMZ에서는 PAT 주소로 보임 → 규칙이 한 번도 맞지 않음	**구간별 실제 출발지(PAT 주소) 기준으로 규칙 작성**



```
10월  08 12:26:09 lb01 kernel: [IPT BLOCK] IN=ens160 OUT= MAC=ff:ff:ff:ff:ff:f
f:b4:2e:99:29:c9:d0:08:00 SRC=172.16.122.1 DST=172.16.255.255 LEN=229 TOS=0x0
0 PREC=0x00 TTL=128 ID=10829 PROTO=UDP SPT=138 DPT=138 LEN=209
1 0월  08 12:26:23 lb01 kernel: [IPT BLOCK] IN=bond0 OUT= MAC=00:0c:29:38:e2:d6
:c4:1f:a0:45:00:00:08:00 SRC=203.230.52.196 DST=203.230.46.132 LEN=60 TOS=0x0
0 PREC=0x00 TTL=55 ID=26376 DF PROTO=TCP SPT=41836 DPT=9100 WINDOW=64240 RES=
0x00 SYN URGP=0
10월  08 12:26:35 lb01 kernel: [IPT BLOCK] IN=ens160 OUT= MAC=ff:ff:ff:ff:ff:f
f:00:0c:29:49:45:c6:08:00 SRC=172.16.14.41 DST=172.16.255.255 LEN=229 TOS=0x0
0 PREC=0x00 TTL=128 ID=22353 PROTO=UDP SPT=138 DPT=138 LEN=209
```

LB [IPT BLOCK] · ① 외부 대역 → tcp/9100 SYN (수신 서비스 없음) · 나머지 두 줄은 관리망 브로드캐스트 (정상 잡음)



```
1 203.230.56.162 - - [06/Oct/2026:15:54:22 +0900] "POST /login/ HTTP/1.1" 500 245639 "http://www.mgai.ac.kr/lo
gin/?next=/notices/" "Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0" host=www.mgai.
ac.kr
203.230.56.162 - - [06/Oct/2026:15:54:38 +0900] "GET /notices/ HTTP/1.1" 200 12741 "http://www.mgai.ac.kr/lo
gin/?next=/notices/" "Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0" host=www.mgai.
ac.kr
203.230.56.162 - - [06/Oct/2026:15:54:49 +0900] "GET /notices/write/ HTTP/1.1" 200 7104 "http://www.mgai.ac.
2 203.230.56.162 - - [06/Oct/2026:15:57:28 +0900] "POST /notices/write/ HTTP/1.1" 302 - "http://www.mgai.ac.kr
/notices/write/" "Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0" host=www.mgai.ac.k
r
203.230.56.162 - - [06/Oct/2026:15:57:38 +0900] "GET /status/ HTTP/1.1" 200 121 "http://www.mgai.ac.kr/notic
es/74/" "Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0" host=www.mgai.ac.kr
```

웹 access_log · 모의 공격자 흐름 추적: ① 로그인 시도(500) ② 게시글 작성 요청(POST 302)

탐지 룰 · 오탐 분석

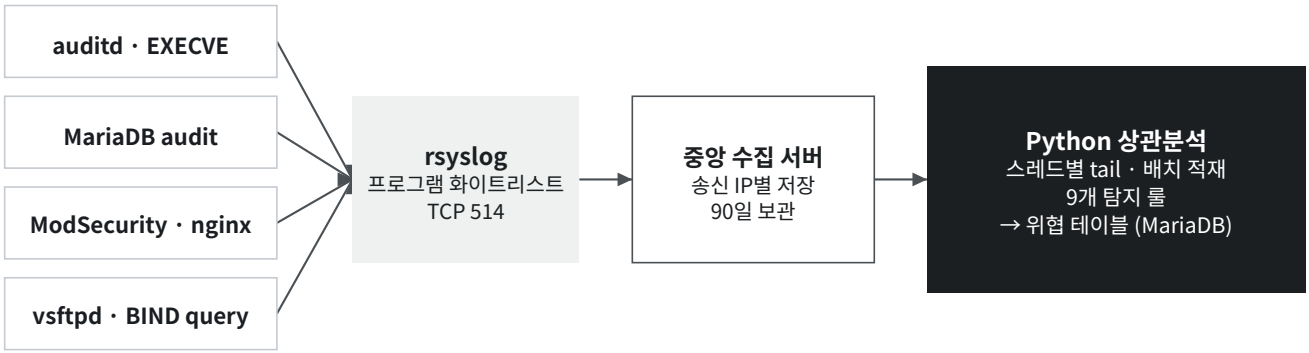
문제
경보 대부분이 판단에 쓸 수 없는 잡음

한 일
로그 계층별 탐지 매트릭스 · Python 상관분석 룰 9개 · 오탐 원인 분석

결과
ModSecurity 경보 64%(920350)를 판단 근거에서 분리

상세 → 부록 A-1

서버 로그 수집 → 상관분석 파이프라인 (직접 구현)



에이전트 설치 스크립트: Rocky / Ubuntu 자동 판별

탐지 룰

- 무차별 대입 (60초 5회)
- 웹 로그인 무차별 대입
- 위험 확장자 스캔
- SQLi · XSS (URL 디코딩 후)
- 리버스 셸 (EXECVE hex 디코딩)
- DNS 위협
- 세션 하이재킹 (쿠키 재사용 IP 변경)

시나리오 × 로그 계층 탐지 매트릭스

	SCN-01 SQL Injection	SCN-02 저장형 XSS · IDOR	SCN-03 브루트포스	SCN-04 리버스쉘 RCE
ModSecurity (요청 본문 X)	942100 libinjection 403 탐지	920350 Host 헤더 매치 XSS 본문 미기록	–	933110 PHP 업로드 탐지 403 탐지
nginx access (POST 본문 X)	302 인증 우회 성공 python-requests	302 XSS 등록 성공 200 IDOR 주문 조회	200 실패 ×44 302 성공 ×3	200 웹셸 실행 성공
MariaDB audit (공격자 IP X)	1064 문법 오류 0 인증 우회 성립 1054 컬럼 탐색 UNION 정보 덤프	UPDATE orders cancelled ×5	SELECT users 사전값 대입 확인	–
auditd (원격 IP X)	–	–	–	EXECVE bash -i REVERSE_SHELL connect failed
서버 로그 미기록 (전 계층 X)	–	세션 beacon 유출 피싱 카드 수집 부정 결제 변조	–	–

시나리오 · 탐지 로그 존재 · 로그 미기록 · (X) = 해당 계층이 남기지 못하는 정보

시나리오별로 어느 계층에 흔적이 남았는지 (빈 칸 = 미기록)

ModSecurity 경보 577건

920350 Host 헤더가 IP **368**

949110 이상 점수 초과 **81**

942100 SQLi **43**

913100 스캐너 UA **29**

그 외 **56**

64%가 920350
IP로 접속하면 공격과 무관하게 발생
→ 공격 판단에서 분리하고
942100 · 949110 · 933110을
DB · auditd 계층과 교차 확인

장애 분석 · 트러블슈팅

문제
원인이 겉으로 드러나지 않는 장애

한 일
응답 · ARP · 스위치 포트 · 실행 환경으로 범위를 좁힘

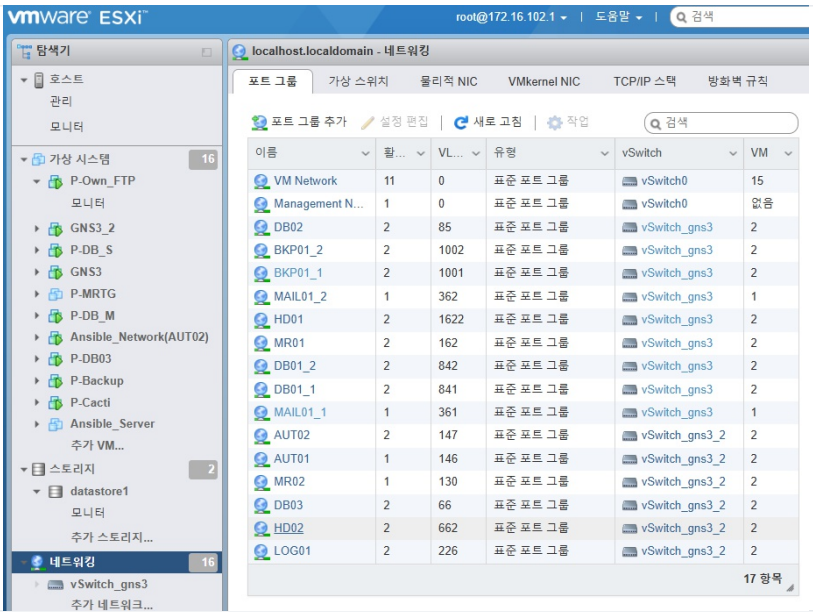
결과
4건 해결 · 추가 9건은 부록

상세 → 부록 A-4

증상	원인	조치
웹메일이 새로고침마다 로그인 / 오류 화면 교대	응답 헤더로 서버 표시 → 오류는 항상 WAS-01, DSN 설정 오류	**WAS-01 분산 제외 → 수정 · php -l 확인 → 복귀**
LB ↔ WEB 트래픽이 스위치 캡처에 안 보임	같은 ESXi 포트그룹 → vSwitch 내부 통신 (관제 사각지대)	**역할별 포트그룹 분리 · 운영 규칙 문서화**
WEB-02만 게이트웨이 · VIP ARP 실패	L2 스위치 포트가 VLAN 1에 남아 있음	**switchport access vlan 지정**
자동화 실행끼리 변수가 섞임	ansible-runner가 이전 실행의 env 재사용	**실행마다 별도 작업 폴더 · 종료 후 정리**


```
"app": "library", "ph": "ph01", "host": "ll.mgai.ac.kr", "client_ip": "203.230.46.158", "path": "/", "time": "17:27:09"}
```


사례 1 · 응답한 WAS를 표시하는 status 응답 (어느 서버가 처리했는지 확인)



사례 2 · 분리 후 ESXi 포트그룹 목록 (서버별 포트그룹)

다계층 방어 · 보안 전 → 후

문제
모든 서버가 공격 가능한 상태로 공개

한 일
네트워크 → 호스트 → 프로세스 계층별 통제를 항목별로 적용

결과
방화벽 · SSH · SELinux · 웹 · DB 구간 등 9개 항목 전환

상세 → 부록 A-2

계층별 접근 통제

네트워크	**라우터 · L3 ACL**	필요한 출발지 · 목적지 · 포트만 허용
경계	**IPS · 방화벽 (pfSense)**	명백한 악성 패킷 실시간 차단
탐지	**네트워크 IDS (SPAN)**	미러링 트래픽 분석 · 경보
호스트	**iptables · firewalld · UFW**	기본 차단 · 서비스 포트 화이트리스트
서비스	**fail2ban · sshd 설정**	반복 실패 IP 차단 · root 원격 접속 차단
프로세스	**SELinux enforcing**	프로세스별 파일 · 포트 접근 제한

보안 전 → 보안 후 (9개 항목)

항목	보안 전	보안 후
방화벽	꺼짐	LB iptables 단계별 정책 · 나머지 firewalld DROP
관리 접속	SSH 22 · root 허용	비표준 포트 · root 차단 · 관리망만
SELinux	permissive	enforcing
웹 서버	버전 노출 · 목록 노출	정보 숨김 · 미등록 접근 403
XFF 신뢰	모든 주소	LB 두 대만 → 실제 공격자 IP 기록
애플리케이션	DEBUG · 원문 출력	운영 모드 · escape + CSP
웹메일	구버전 · installer 노출	최신 버전 · installer 삭제
구간 암호화	DB · 메일 평문	DB TLS · IMAPS 993 · 587
SNMP	public · 제한 없음	서버별 커뮤니티 · 감시 서버만

항목마다 Ansible 보안 토글로 켜고 끌 수 있게 만들어, 같은 공격을 보안 전 · 후로 반복 검증

접근 통제 · 차단 정책

문제
웹 · 앱 서버에 누구나 직접 접근 가능

한 일
LB iptables 단계별 정책 · 서버 firewalld 화이트리스트 · 사전 검증과 롤백

결과
외부 → 웹 서버 직접 접속 차단 · 잘못된 규칙은 자동 복구

상세 → 부록 A-2

LB iptables 처리 순서

ESTABLISHED → INVALID 차단 → F2B → BLACKLIST → 서비스 허용 → LOG → DROP

fail2ban 차단(F2B)과 공용 차단 목록(BLACKLIST)을 허용 규칙보다 앞에 · 허용되지 않은 패킷은 [IPT BLOCK]으로 기록 후 폐기

```
[root@lb01 ~]# iptables -L INPUT -n -v --line-numbers
Chain INPUT (policy DROP 0 packets, 0 bytes)
num   pkts bytes target     prot opt in     out     source               destination
1        0     0 ACCEPT     all  --  lo     *       0.0.0.0/0            0.0.0.0/0
2      238K   49M ACCEPT     all  --  *      *       0.0.0.0/0            0.0.0.0/0           ctstate RELATED,ESTABLISHED
3       19   892 DROP       all  --  *      *       0.0.0.0/0            0.0.0.0/0           ctstate INVALID
4    25199 1739K F2B        all  --  *      *       0.0.0.0/0            0.0.0.0/0
5    25199 1739K BLACKLIST  all  --  *      *       0.0.0.0/0            0.0.0.0/0
6        3   284 ACCEPT     icmp --  *      *       0.0.0.0/0            0.0.0.0/0           /* 임시 편의 ICMP 허용 */
7        0     0 ACCEPT     tcp  --  *      *       172.16.14.1          0.0.0.0/0           tcp dpt:22 /* 임시 편의 관리자 IP01 */
8       32  1920 ACCEPT     tcp  --  *      *       172.16.102.5         0.0.0.0/0           tcp dpt:22 /* 임시 편의 관리자 IP01 */
9        0     0 ACCEPT     tcp  --  *      *       203.230.44.130       0.0.0.0/0           tcp dpt:22 /* AUT01 SSH 관리 */
10       0     0 ACCEPT     udp  --  *      *       203.230.44.130       0.0.0.0/0           udp dpt:161 /* SNMP 모니터링 */
11     207 12436 ACCEPT     all  --  *      *       203.230.46.134       0.0.0.0/0           /* 뒷단 WS01/WS02 */
12       0     0 ACCEPT     all  --  *      *       203.230.46.135       0.0.0.0/0           /* 뒷단 WS01/WS02 */
13       0     0 ACCEPT     112  --  *      *       203.230.46.133       0.0.0.0/0           /* keepalived VRRP */
14     512 30173 ACCEPT     tcp  --  *      *       0.0.0.0/0            203.230.46.136      multiport dports 80,443 /* 웹 (VIP) */
15       1    60 ACCEPT     tcp  --  *      *       0.0.0.0/0            203.230.46.136      tcp dpt:25 /* SMTP 레드팀 메일 (VIP) */
16   24444 1694K LOG DROP   all  --  *      *       0.0.0.0/0            0.0.0.0/0           /* 그 밖의 인바운드 */
```

LB iptables · ① 기본 정책 DROP ② INVALID 차단 → F2B → BLACKLIST (허용보다 앞) ③ 나머지는 기록 후 폐기

```
[root@ws01 ~]# firewall-cmd --zone=public --list-all
public (active)
  target: DROP
  ...
  rich rules:
        rule priority="-40" family="ipv4" source address="203.230.46.133" port port="35439" protocol="tcp" accept
        rule priority="-40" family="ipv4" source address="203.230.46.132" port port="35439" protocol="tcp" accept
        rule priority="-30" family="ipv4" source address="203.230.44.130" service name="ssh" accept
        rule priority="-20" family="ipv4" source address="203.230.44.130" port port="161" protocol="udp" accept
        rule priority="-10" family="ipv4" source address="203.230.44.130" protocol value="icmp" accept
```

중간 생략

WEB firewalld · ① 기본 DROP ② LB 두 대만 서비스 포트 허용

```
[root@lb01 ~]# fail2ban-client status haproxy-http
Status for the jail: haproxy-http
|- Filter
|  |- Currently failed: 0
|  |- Total failed:     3
|  `- File list:        /var/log/haproxy.log
`- Actions
   |- Currently banned: 0
   |- Total banned:     0
   `- Banned IP list:
```

fail2ban haproxy-http jail

```
C:\Users\Admin>curl -m 5 http://203.230.46.134:35439
curl: (28) Connection timed out after 5003 milliseconds
```

외부 PC → WEB 직접 접속 타임아웃 (차단 확인)

안전한 적용 (플레이북)

규칙 편집 그룹별 규칙 파일 → **미리보기** 임시 네임스페이스 검증 → **차이만 적용** 백업 · 롤백 타이머 → **새 접속 확인** 실패 시 자동 복구

웹 공격 방어 · 구간 암호화

문제
게시판 Stored XSS 실행 · 서버 간 평문 통신

한 일
escape + CSP · 사설 Root CA로 4개 구간 TLS

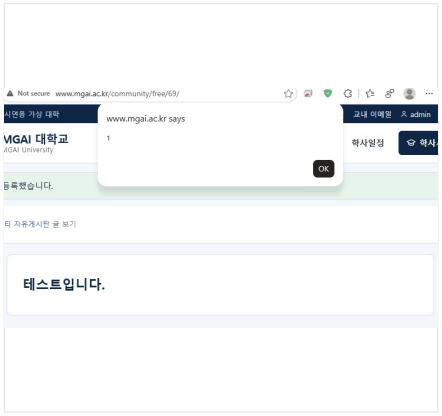
결과
스크립트가 문자로 출력 · DB 연결 TLS 1.3

상세 → 부록 A-2

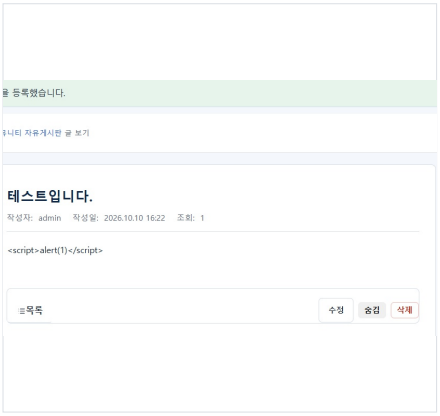
Stored XSS · 보안 전 → 후



① 스크립트를 넣은 게시글 작성



② 보안 전 · 스크립트 실행



③ 보안 후 · 문자 그대로 출력

게시판 · 공지 · 검색어 escape | 엄격한 CSP | ModSecurity | DEBUG 해제 | installer 삭제 | 서버 버전 숨김

사설 Root CA → 4개 구간 TLS

사설 Root CA
서버 인증서 발급
CA 검증

→

사용자 → LB
HTTPS · SSL 종료

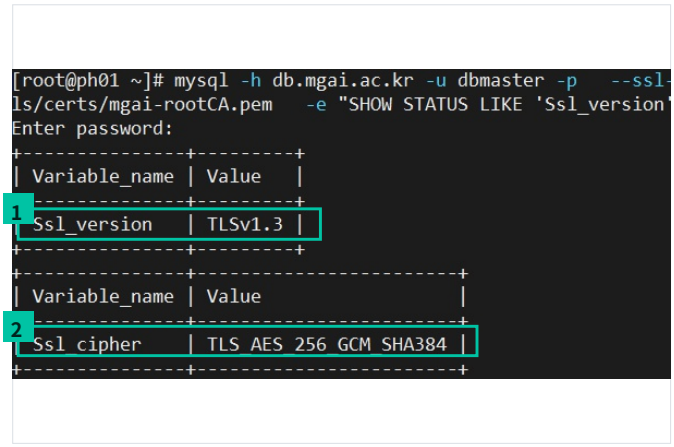
WAS → DB
MariaDB TLS 1.3 · CA 검증

웹메일 → 메일
IMAPS 993 · 587

외부 → 메일
SMTP STARTTLS



브라우저 HTTPS · 사설 CA 체인



WAS → DB · ① TLSv1.3 ② TLS_AES_256_GCM_SHA384

주정통 진단 자동화 · 설계

문제
장비 유형마다 점검 항목과 방법이 달라 수작업 점검이 오래 걸림

한 일
유형별 모듈 8종을 하나의 실행 틀로 통합 · 원격 SSH 병렬 + 로컬 실행 · Unix · Windows · PC 모듈 작성

결과
점검 항목 241개 자동화

상세 → 부록 A-3

KISA 주요정보통신기반시설 기술적 취약점 분석 · 평가 기준 | Unix · Windows · PC 모듈 직접 작성

비밀번호는 실행 때 입력 · 파일에 저장 안 함 | 점검 대상 유형 자동 탐지

실행 방식 2가지

① 중앙 서버 원격 점검
중앙 서버에서 일괄 실행

- **device_list.json 로드**
  점검 대상의 IP · 계정 · 장치 유형(type)
- **장치별 thread 생성**
  장치 단위 병렬 점검 · 장치당 1 ~ 15초
- **SSH 연결**
  unix / windows = paramiko · network = netmiko
- **점검 모듈 실행**
  type에 매핑된 모듈이 (status, reason) 반환
- **취합 및 DB 전송**
  전체 종료 후 JSON 배치 전송

② 로컬 자체 점검
점검 대상 장비에서 직접 실행

- **OS · 서버 유형 판별**
  /etc/os-release 등을 직접 읽어 판별
- **추가 점검 대상 선택**
  DBMS 점검 여부를 실행 시 입력
- **점검 항목 실행**
  check_list 각 항목을 로컬 명령으로 실행
- **결과 출력 및 저장**
  콘솔 표 출력 + 로컬 JSON 파일 저장

① 중앙 서버에서 장비별 스레드로 원격 점검 · ② 대상 장비에서 직접 로컬 점검

구조 · 점검 로직과 실행 로직 분리

메인 코드 (main.py)

접속 · 병렬 처리 · 결과 취합 · DB 전송
SSHConnection 객체 생성 후 주입
장치 유형 ↔ 모듈 매핑 테이블 관리

SSHConnection 주입 →
← (status, reason) 반환

유형별 점검 모듈

Unix U-XX	Windows W-XX	웹 서비스 WEB-XX	네트워크 N-XX
PC PC-XX	DBMS D-XX	Web App	가상화 HV-XX

점검 로직과 실행 로직 분리
모듈은 판정만, 메인은 실행 · 수집 · 전송

공통 인터페이스 규약
같은 형태의 클래스 → 내부 구현 몰라도 호출

연결 객체 주입
같은 모듈을 원격 · 로컬 양쪽에서 재사용

매핑 테이블 기반 확장
유형을 추가해도 메인 로직 수정 불필요

주정통 진단 자동화 · 결과와 조치

문제
점검 결과를 모아도 조치로 이어지지 않음

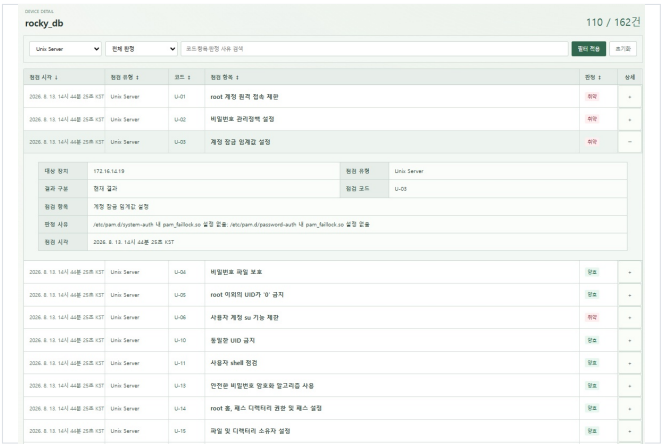
한 일
결과 DB 적재 · Ansible로 점검(jtc_check) → 조치(jtc_fix) 연결

결과
5대 492개 항목 판정 · 13개 항목 자동 조치

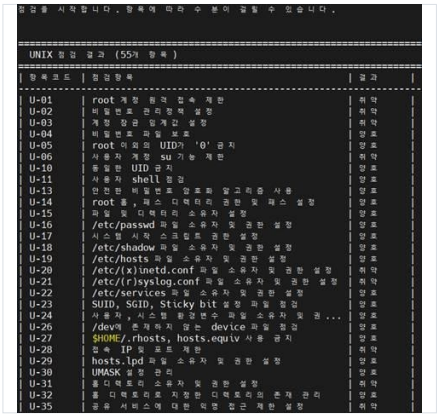
상세 → 부록 A-3

점검 결과 · 5대 492개 항목

243 양호	103 취약	100 검토 · 오류	46 해당 없음



장비별 상세 판정 · 근거



Unix 로컬 점검 출력 (55개 항목)

점검 → 조치 연결 (Ansible)

jtc_check
점검 코드 배포 · 실행
→ **결과 수집**
서버별 JSON
→ **검토**
취약 항목 확인
→ **jtc_fix --check**
바뀔 내용 미리보기
→ **적용 · 재점검**
한 대씩

자동 조치 13개 항목 (jtc_fix)

U-01 root 원격 접속 차단 | U-02 비밀번호 정책 | U-03 계정 잠금 | U-04 shadow 권한 | U-13 SHA512 | U-16 passwd 권한
U-19 hosts 권한 | U-21 rsyslog.conf 권한 | U-22 services 권한 | U-28 TCP Wrapper | U-30 UMASK 022
U-36 r 계열 서비스 비활성 | U-37 crontab 권한

발견한 점 U-01 조치가 sshd_config에 들어가도 sshd_config.d의 drop-in 설정이 우선하면 실제로는 적용되지 않음
→ 조치 후에는 설정 파일이 아니라 실제 적용값(sshd -T)으로 재점검해야 함

정책 배포 자동화 · Ansible

문제
서버 8대에 같은 설정을 손으로 반복

한 일
역할별 플레이북 · --check 미리보기 · 한 대씩 적용

결과
보안 토글 13개를 항목별로 일괄 전환

상세 → 부록 A-3

플레이북 역할별 · group_vars → **문법 검사** --syntax-check → **미리보기** --check --diff → **적용** --limit 한 대씩 → **확인** PLAY RECAP

명령 형식

```
$ ansible-playbook -i inventory 04_apache.yaml --syntax-check
$ ansible-playbook -i inventory security.yaml --tags sec_firewall -e sec_firewall=true --check --diff
$ ansible-playbook -i inventory lb_firewall.yaml --limit lb01 --check
$ ansible-playbook -i inventory lb_firewall.yaml --limit lb01
$ ansible-playbook -i inventory 06_django.yaml -e sec_ph_web_xss=true --check --diff
```

보안 설정은 항목별 태그로 하나씩 켜고 끔 · 비밀값 작업은 no_log · diff: false로 출력 차단

보안 토글 13개 (보안 전 ↔ 후를 항목별로 전환)

방화벽 | SELinux | LB 상태 화면 제한 | WEB 정보 숨김 | XFF 신뢰 범위 | 미등록 접근 403 | 웹메일 문서 루트 | php-fpm 출발지 제한 | Django 운영 모드 | installer 삭제 | 업로드 제한 | XSS 방어 | SNMP 출발지 제한

실행 화면

1

```
[ans@localhost playbooks]$ ansible-playbook 06_django.yaml -e s
ec_ph_web_xss=true --check --diff

PLAY [django] ***********************************************
****************

TASK [Gathering Facts] **************************************
*****************
ok: [203.230.46.164]
ok: [203.230.46.165]

TASK [코드 있는 앱 확인] ************************************
***************
included: /home/ans/ansible/playbooks/tasks/django_code_apps.yaml
 for 203.230.46.164, 203.230.46.165

TASK [배포할 코드 확인 (컨트롤러)] ***************************
***************
skipping: [203.230.46.164] => (item=univ)
skipping: [203.230.46.164] => (item=library)
skipping: [203.230.46.164]
skipping: [203.230.46.165] => (item=univ)
skipping: [203.230.46.165] => (item=library)
skipping: [203.230.46.165]

TASK [코드 없음 → 임시 앱] **********************************
***************
ok: [203.230.46.164]
ok: [203.230.46.165]
```

보안 토글 하나(-e)를 켠 상태로 미리보기 (--check --diff)

```
[ans@localhost playbooks]$ ls
00_prep.yaml         files                  logrotate.yaml
01_base.yaml         filter_plugins         mrtg.yaml
02_bonding.yaml      group_vars             net_mode.yaml
03_php-fpm.yaml      guacamole.yaml         ph_tls.yaml
04_apache.yaml       guacamole_clients.yaml security
05_roundcube.yaml    host_vars              security.yaml
06_django.yaml       inventory              site.yaml
07_haproxy.yaml      jtc                    sql
08_keepalived.yaml   jtc_check.yaml         tasks
09_monitoring.yaml   jtc_fix.yaml           templates
10_demo_data.yaml    jtc_net_check.yaml     vars
ansible.cfg          jtc_results            ws_firewall.yaml
cacti.yaml           lb_firewall.yaml       zone_firewall.yaml
db01_setup.yaml      lb_ws_backend.yaml
```

플레이북 구성 · 역할별 번호 · 방화벽 · 점검 플레이북

```
[ans@localhost playbooks]$ ansible all -m ping
203.230.44.147 | SUCCESS => {
    "changed": false,
    "ping": "pong"
}
203.230.45.84 | SUCCESS => {
    "changed": false,
    "ping": "pong"
}
```

키 기반 접속 확인 (ansible all -m ping)

A-1 로그 · 탐지

수집 구성

수집 대상	웹 접근 로그 · 방화벽 차단 로그 · auditd (EXECVE) · DB audit · ModSecurity · DNS 질의 로그
수집 방식	syslog로 기록하는 서비스: facility · 프로그램 이름으로 선택 파일에만 기록하는 서비스: imfile로 파일을 읽어 태그를 붙여 전송
전송	rsyslog → 중앙 수집 서버 TCP 514 · 디스크 큐 + 재시도 (전송 실패 시 유실 방지) · 프로그램 화이트리스트
저장	송신 IP별 파일 분리 · 90일 보관
신뢰성	프록시 뒤 실제 IP: 신뢰하는 프록시에서 온 X-Forwarded-For만 사용 NAT 구간: 실제 출발지(PAT 주소) 기준으로 해석 · 규칙 작성

탐지 룰 (Python 상관분석)

룰	조건	근거 로그
무차별 대입	60초 안에 인증 실패 5회	시스템 인증 로그
웹 로그인 무차별 대입	같은 출발지의 로그인 실패 반복	웹 접근 로그
위험 확장자 스캔	위험 확장자 파일 요청 반복	웹 접근 로그
SQLi · XSS	URL 디코딩 후 시그니처 매칭	웹 · ModSecurity · DB
리버스 셸	EXECVE 인자를 hex 디코딩 후 셸 연결 패턴	auditd
DNS 위협	의심 도메인 · 비정상 질의	DNS 질의 로그
세션 하이재킹	같은 세션 쿠키가 다른 IP에서 사용	웹 접근 로그

처리: 로그 파일별 스레드로 tail → 배치로 DB 적재 · 종료 신호 시 버퍼 저장

오탐 개선

증상	정상 정렬 쿼리가 SQLi로 탐지
원인	DB 시그니처 'order by'가 일반 정렬 구문까지 포함
개선	'order by <숫자>' 형태(컬럼 수 추측 패턴)로 조건 한정

A-2 접근 통제 · 암호화 · 가용성

iptables 순서	ESTABLISHED 허용 → INVALID 차단 → fail2ban(F2B) → 공용 차단 목록(BLACKLIST) → 서비스 허용 → LOG → DROP
firewalld	zone target DROP · rich rule로 출발지 + 포트를 함께 지정 · 관리 접속은 관리 주소에서만
UFW · TCP Wrapper	UFW: 기본 차단 · 출발지별 허용 (firewalld와 같은 Ansible 작업으로 관리) TCP Wrapper: hosts.deny 'ALL: ALL' 여부를 점검 항목으로 확인 (Rocky 9는 tcp_wrappers 제거 → 호스트 방화벽으로 대체)
fail2ban	프록시 로그의 4xx · 429 응답 5분 20회 → 1시간 차단 · 차단 기록은 규칙 재적용 후에도 유지
차단 목록	공용 목록 하나를 모든 프록시 서버의 BLACKLIST 체인에 동시 반영 (VIP 이동 시에도 유지)
안전한 적용	임시 네트워크 네임스페이스에서 규칙 검증 → 차이만 적용 → 롤백 타이머 → 새 SSH 접속 확인 실패 시 자동 복구
웹 방어	게시판 · 공지 · 검색어 escape + 엄격한 CSP · DEBUG 해제 · 서버 버전 숨김 · 디렉터리 목록 끔 · installer 삭제
업로드	허용 목록 + 파일 서명 + 크기 제한 · 강제 다운로드
인증서	사설 Root CA로 서버 인증서 발급 · 클라이언트는 CA 인증서로 서버 검증
TLS	사용자 → 프록시 HTTPS (TLS 1.2+) · 앱 → DB TLS 1.3 (CA 검증) · 웹메일 → 메일 IMAPS 993 / 587 · 외부 → 메일 SMTP STARTTLS
SELinux	enforcing · 프록시 연결 · 홈 디렉터리 · DB 연결 boolean만 허용 · 인증서 라벨 복구
가용성	VRRP (MASTER / BACKUP) · NIC 본딩 active-backup, 감시 대상은 실제 SVI · 헬스체크 후 한 대씩 전환

A-3 자동화 · 점검

Ansible CLI 운영

구성	ansible-core 2.14 (서버) · Ansible 2.9 (구형 Cisco 장비) · 역할별 플레이북 00_prep ~ 09_monitoring · 그룹 설정은 group_vars
실행 순서	--syntax-check → --check --diff 미리보기 → --limit로 한 대씩 적용 → PLAY RECAP 확인
보안 토글	security.yaml --tags <항목> -e <항목>=true|false (항목별로 보안 전 ↔ 후 전환)
비밀값	비밀번호를 다루는 작업은 no_log · 설정 파일 작성은 diff: false로 미리보기 출력에서도 차단
키 관리	호스트 키 지문 확인 후 고정 · 배포 키에 접속 출발지(from=) 제한

보안 토글 13개

방화벽 · SELinux	방화벽 활성 · SELinux enforcing
LB 상태 화면	자기 주소에서만 · 로그인 필요
WEB 정보 숨김 · 미등록 접근	버전 · TRACE 숨김, 디렉터리 목록 끔 · IP / 모르는 도메인은 403
XFF 신뢰 범위	X-Forwarded-For는 프록시에서 온 것만 신뢰
웹메일 문서 루트	public_html만 공개 (installer 등 비공개)
php-fpm 출발지	9000 포트를 웹 서버에서만
Django 운영 모드	DEBUG 0 · 허용 도메인 · systemd 제한
installer 삭제 · 업로드 · XSS	installer 삭제 · 업로드 허용 목록 · escape + CSP
SNMP 출발지	조회를 감시 서버에서만

주정통 점검 도구

실행	원격 SSH (장비별 스레드 병렬) · 로컬 실행 · 점검 대상 유형 자동 탐지
구조	유형별 어댑터 8종 (Unix · Windows · PC · WEB · N/W · DBMS · WebApp · HV) · 결과 DB 적재
작성 모듈	Unix 서버 · Windows 서버 · PC

A-4 트러블슈팅 추가 사례

증상	원인	조치
HAProxy가 예비 LB에서만 기동 실패	인증서 파일 SELinux 라벨	restorecon으로 라벨 복구
fail2ban 첫 차단이 60초 지연	ignoreself가 호스트 이름을 DNS 조회 (DNS 도달 불가)	ignoreself 끄고 LB 주소는 ignoreip
방화벽 롤백이 복구하지 못함	빈 백업 복원 · 롤백 타이머 기본 1분 지연	백업에 filter 테이블 포함 · 타이머 정밀도 1초 · 새 TCP 접속으로 확인
VIP 이동 시 차단 IP가 풀림	두 LB의 fail2ban이 따로 동작	공용 차단 목록을 두 LB에 동시 반영
LB 본딩 링크 감시 흔들림	ARP 감시 대상이 GLBP 가상 주소 (응답 MAC이 번갈아 바뀜)	실제 SVI 두 개를 감시 대상으로 변경
웹메일 로그인 실패	DB 방화벽이 메일 서버 → 3306 미허용	DB 규칙 추가 후 정상
메일 서버가 외부 중계 허용	mynetworks가 /16 대역 전체	WAS 두 대만 허용 · 인증은 TLS 후에만
배포 후 웹 서비스 다운	플레이북이 Gunicorn 진입점을 기본값으로 덮어씀	서버에 있는 앱 코드를 감지해 진입점 유지
웹 포트 축소 후 내부 사용자 접속 끊김	NAT 포트포워드 경로가 80 사용	80과 해당 경로 재허용 · 포트 폐쇄 전 접속 로그 확인